

Политике, конфигурација и безбедносна видљивост

Управљање правилима, конфигурацијом и безбедносним
записима



Садржај презентације

01

Правило и контрола

Политика, конфигурација,
контрола и доказ · 05–10

02

Важење и мерење

Ток до доказа, верзије и
безбедносне метрике · 11–18

03

Имплементација

Откривање drift-а, тест и
безбедносни запис · 19–25

04

Провера и примена

Грешке, видљивост и
пројекат · 26–31

Увод

Разлика између очекиваног правила и стварног исхода (03–04).

Политика, конфигурација и доказ

Политика дефинише очекивано понашање, конфигурација одређује вредности у окружењу, а доказ потврђује стварни исход.

ПРЕДМЕТ АНАЛИЗЕ

Ризик који се анализира

Безбедносна правила постају поуздана тек када су видљива, верзионисана и проверљива. Правило расуто кроз неколико метода није лако објаснити, прегледати нити променити без нежељених последица. Политика зато представља договорено правило, а конфигурација његову примену у конкретном окружењу.

ЗНАЧАЈ

Значај за безбедност система

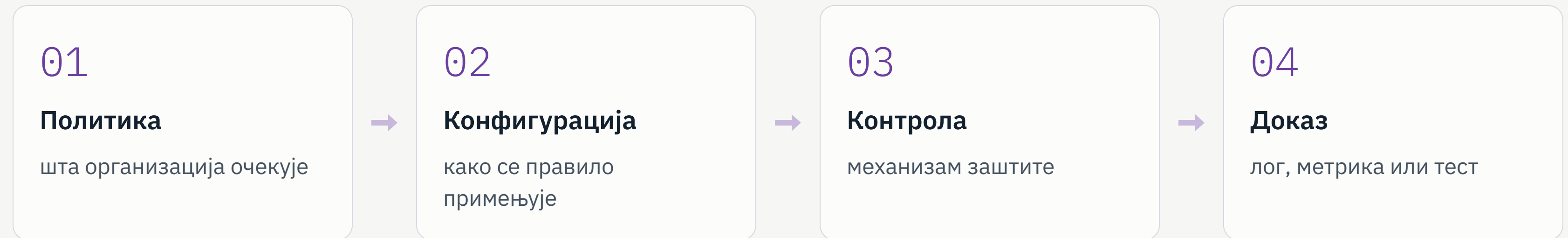
Видљивост не служи само реаговању на инцидент. Она омогућава тиму да разуме одлуку система, прати одступање од очекиваног стања и повеже догађаје кроз различите слојеве апликације.

КРИТЕРИЈУМ ПРОВЕРЕ • Проверљив резултат

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

Основни појмови

Политика, конфигурација, контрола и доказ имају различите улоге у управљању безбедносним правилом.



ЗАКЉУЧАК

Правило може бити добро написано, а контрола ипак неефективна. Доказ повезује очекивање са реалним понашањем.

01

ПРВИ ДЕО

Правило и контрола

Политика описује намеру, конфигурација њену примену, контрола механизам заштите, а доказ стварни исход.

Политика

Конфигурација

Контрола

Доказ

Политика

шта организација очекује

01

**Политика изражава намеру:
шта мора да важи, за кога и од
ког датума.**

Питање: који улаз покреће ову
одлуку?

02

**Објављена верзија политике
се не мења накнадно, нова
намера постаје нова верзија.**

Питање: која граница мора бити
видљива?

03

**Свака верзија чува разлог и
контекст промене, па се стара
одлука може објаснити.**

Питање: који доказ остаје после
исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Које безбедносно правило у вашој целини мора имати власника, верзију и датум важења?

Конфигурација

како се правило примењује

01

Конфигурациона вредност је конкретно стање система и има власника и очекивану вредност.

Питање: који улаз покреће ову одлуку?

02

Референтна конфигурација одређује најмању дозвољену строгост, строже подешавање није одступање.

Питање: која граница мора бити видљива?

03

Свака промена вредности оставља траг: ко ју је променио, када и зашто.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Које подешавање у вашем систему тихо слаби заштиту ако се промени?

Контрола

механизам заштите

01

Контрола пореди стварно стање са референтним и за свако правило даје један јасан исход.

Питање: који улаз покреће ову одлуку?

02

Нова контрола се додаје као нова класа, без измене постојећих провера.

Питање: која граница мора бити видљива?

03

Налаз садржи назив контроле, очекивану вредност и стварну вредност.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Која контрола у вашој целини проверава да правило заиста важи?

Доказ

лог, метрика или тест

01

Доказ показује стваран исход, а не само да је правило записано.

Питање: који улаз покреће ову одлуку?

02

Корелациони идентификатор повезује налаз са провером која га је произвела.

Питање: која граница мора бити видљива?

03

Тест са одступањем и тест без одступања заједно доказују да контрола ради.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Којим записом бисте показали да је одступање откривено и када?

Политика, процедура и контрола

Поређење приказује функцију сваког елемента и ограничење његове самосталне примене.

Елемент	Улога	Пример доказа
Политика	Одређује правило и циљ заштите.	Верзионисан текст са власником.
Процедура	Описује како људи или систем спроводе правило.	Преглед корака или аутоматизовани ток.
Контрола	Спречава, открива или ограничава ризик.	Тест, лог или резултат провере.
Метрика	Показује тренд или одступање.	Дефинисан праг и извор података.

02

ДРУГИ ДЕО

Важење и мерење

Историја политике и јасна безбедносна метрика омогућавају да одлука остане објашњива и после промене система.

Верзије

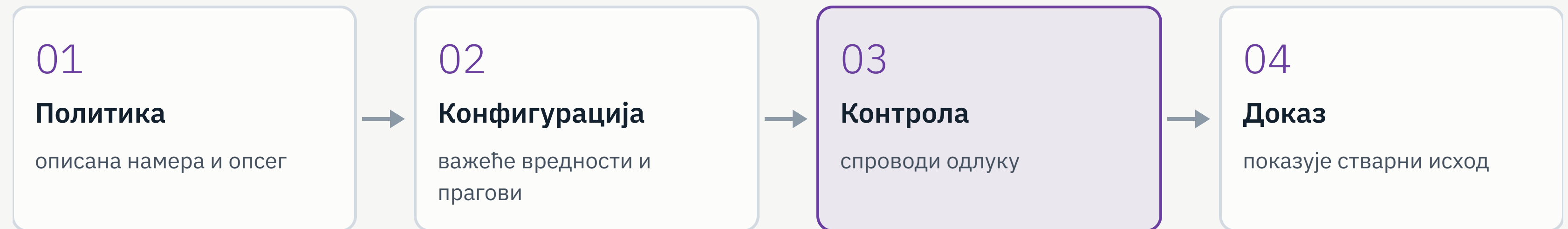
Власник

Метрика

Корелација

Модел од правила до доказа

Правило може бити добро написано, а контрола ипак неефективна. Доказ повезује очекивање са реалним понашањем.



ЕЛЕМЕНТИ АНАЛИЗЕ

Анализа сваког корака обухвата покретача, место одлуке и траг који остаје после исхода.

Како се бира безбедносна метрика

Процес приказује улазе, место одлуке и доказ који остаје после исхода.

КОНТЕКСТ

Како се бира безбедносна метрика

Избор метрике почиње питањем које оператер или власник система треба да реши. Након тога се одређују извор, период посматрања и праг за покретање активности.

01

Понашање

Које понашање желимо да разумемо или ограничимо?

02

Извор

Који догађаји поуздано представљају то понашање?

03

Активност

Ко је власник прага и шта ради када се праг пређе?

04

Тумачење

Како разликујемо нормалну промену рада од безбедносног одступања?

Правило без доказа је само намера

Наведена правила остају видљива у имплементацији, тестовима и ревизији.

01

Нова верзија политике чува разлог и контекст у коме је претходна одлука била исправна.

Јасно правило

02

Конфигурациона вредност има власника, значење и очекивани опсег.

Проверљива примена

03

Корелациони идентификатор повезује један безбедносни ток кроз слојеве система.

Видљив доказ

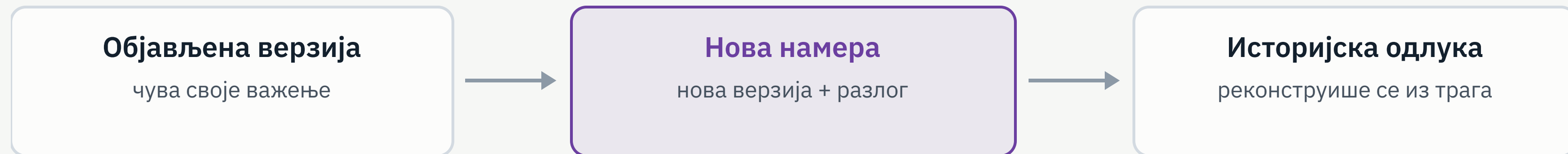
Случај: промена правила без губитка историје

Случај повезује опште правило са конкретним контекстом, серверском провером и очекиваним исходом.

СЦЕНАРИО

Пример: промена правила без губитка историје

Тим пооштрава правило за приступ административном интерфејсу. Ако старо правило само препише новим, касније не може да објасни зашто је ранији приступ био дозвољен нити да реконструише које је очекивање тада важило. Верзионисање очувава смисао историјских одлука и омогућава њихову накнадну реконструкцију.

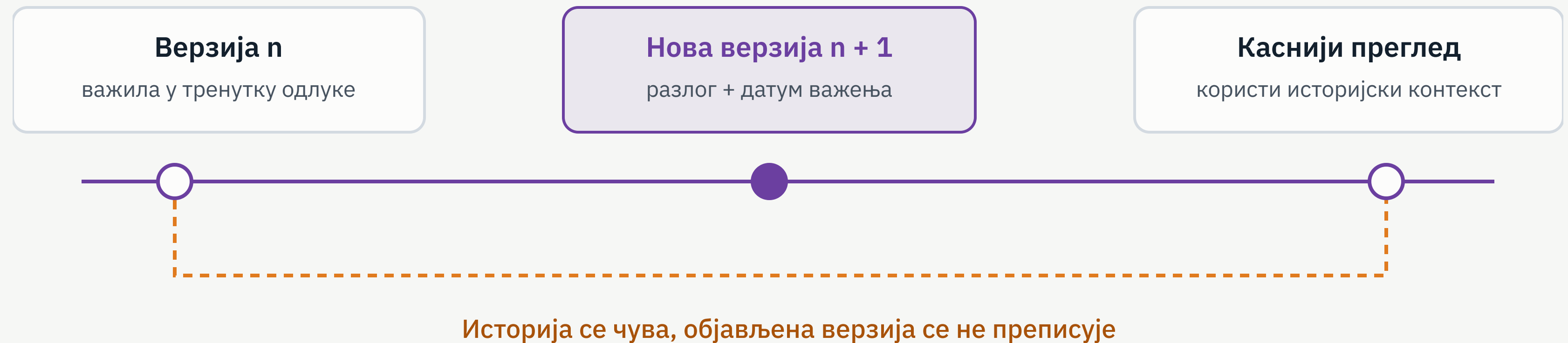


Три питања за серверску границу

01	Контекст	Политика описује намеру и важење, док конфигурација чува вредности којима се та намера примењује у окружењу.
02	Обухват	Свака промена која утиче на одлуку има власника, датум и јасан разлог.
03	Доказ	Лог, метрика или тест дају доказ да систем ради према активном правилу, а не само да је правило записано.

Верзија објашњава одлуку у времену

Измена намере ствара нову верзију, а претходна задржава своје важење.



Доказ

Запис треба да повеже одлуку са политиком и верзијом која је важила у тренутку њеног доношења.

Метрика почиње питањем, завршава радњом

Елемент	Илустративни пример	Зашто је потребан
Питање	Да ли конфигурација одступа од референтне?	Јасна сврха мерења
Извор и период	Налази контрола у једном периоду	Поновљива мера
Власник и праг	Тим дефинише праг и очекивани опсег	Одговорност за тумачење
Активност	Проверити узрок и кориговати одступање	Одступање води ка поступку

Напомена

Праг је договорена вредност конкретног система. Илустрација не прописује универзалан праг.

03

ТРЕЋИ ДЕО

Видљива примена

Контрола пореди референтно и стварно стање. Тест потврђује налаз, а запис омогућава његово објашњење.

Baseline

Drift

Тест

Ревизиони запис

Примена у развоју

Тим примењује тему кроз серверске провере, тестове и ревизионе записе током развоја.

РАЗВОЈНИ КОНТЕКСТ

Примена принципа у коду

Тим бира кључне одлуке које може да објасни на основу лога и теста. Избор обухвата догађаје чији би нејасан исход отежао истрагу, преглед приступа или корекцију конфигурације.

01 Дефинисана одлука и њена граница.

02 Серверска имплементација провере.

03 Позитиван и негативан доказ.

Политика, конфигурација и контрола имају различите улоге

Референтна вредност је правило, тренутна вредност је стање, а контрола их пореди.

C# • илустративни пример

```
1 public sealed class MinimumPasswordLengthControl
2     : IConfigurationControl
3 {
4     public const string Name = "password.minLength";
5     public ConfigurationFinding? Check(
6         SecurityBaseline baseline, SecurityConfiguration current) =>
7         current.MinimumPasswordLength < baseline.MinimumPasswordLength
```

ТУМАЧЕЊЕ

Политика изражава намеру, конфигурација конкретно стање, а контрола производи експлицитан исход.

Контрола враћа експлицитан исход

C# • илустративни пример

```
8           ? new(  
9           Name,  
10          baseline.MinimumPasswordLength.ToString(),  
11          current.MinimumPasswordLength.ToString())  
12          : null;  
13 }
```

БЕЗБЕДНОСНА ГРАНИЦА

Одступање је експлицитан налаз са очекиваном и стварном вредношћу.

Drift мора бити видљив и проверљив

Тест проверава да одступање конфигурације производи видљив и поновљив исход.

C# • илустративни пример

```
1  [Test]
2  public void
3  MinimumPasswordLength_WhenShorterThanBaseline_ReportsFinding()
4  {
5      var finding = new MinimumPasswordLengthControl().Check(
6          Baseline,
7          new SecurityConfiguration(10, true));
8      Assert.That(finding, Is.EqualTo(new ConfigurationFinding(
9          MinimumPasswordLengthControl.Name, "14", "10")));
10 }
```

ДОКАЗ

Тест проверава назив контроле, очекивану и стварну вредност одступања.

ОЧЕКIVАНИ ИСХОД

Тест мења једну вредност конфигурације и очекује један јасан налаз.

Садржај безбедносног записа

Запис садржи контекст потребан за реконструкцију одлуке, без тајни и непотребних личних података.

JSON • пример безбедносног записа

```
1  {  
2    "policyId": "data-export",  
3    "version": 4,  
4    "validFrom": "2026-10-01",  
5    "baseline": "api-v4",  
6    "decision": "denied",  
7    "reason": "configuration_drift"  
8  }
```

ДОВОЉНО

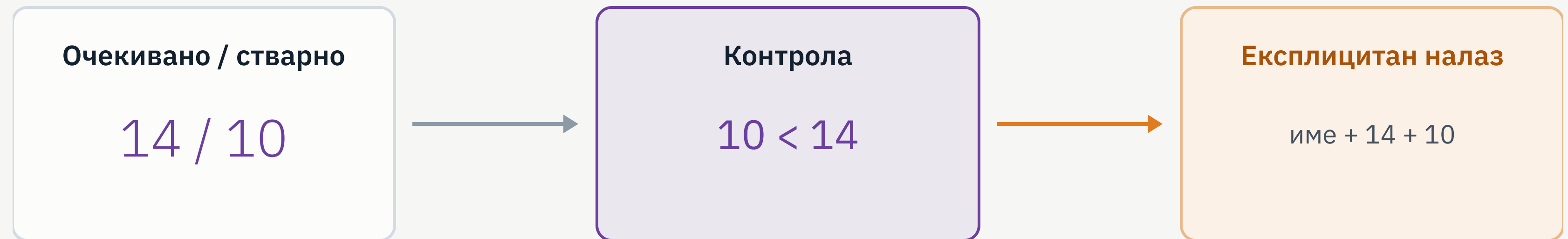
Актер, радња, циљ, исход и разлог
Временска ознака и correlation ID повезују
траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, token, тајна и сувишан садржај
Траг не сме да постане нови извор цурења
или збирка непотребних података.

Drift је разлика која има објашњење

Приказ прати достављени наставни тест за MinimumPasswordLengthControl.



Тестови у оба смера

Поред одступања, провери и стање без одступања. Тако се разликује исправна контрола од механизма који увек пријављује налаз.

04

ЧЕТВРТИ ДЕО

Провера и примена

Критеријуми потпуности, честе грешке и примена на један стварни пројектни сценарио.

Грешке

Критеријуми

Пројекат

Честе грешке у имплементацији

Грешке настају када контекст, место одлуке или доказ остану нејасни.

01

Уређивање објављене политике на месту без историје.

Нема јасног власника одлуке.

02

Тајне у конфигурационим датотекама или логовима.

Не постоји негативан сценарио.

03

Метрика без јасног питања на које треба да одговори.

Доказ не показује стварни исход.

Критеријуми безбедносне видљивости

Доказ треба да буде актуелан, поновљив и разумљив другом члану тима.

ОБРАЗЛОЖЕЊЕ

Видљивост као способност тима

Безбедносна видљивост не значи чување сваког детаља заувек. Значи да се за важну одлуку може пронаћи довољно контекста: где је настала, кроз које слојеве је прошла и зашто је завршила успехом или одбијањем. Корелациони идентификатор даје заједничку нит том објашњењу.

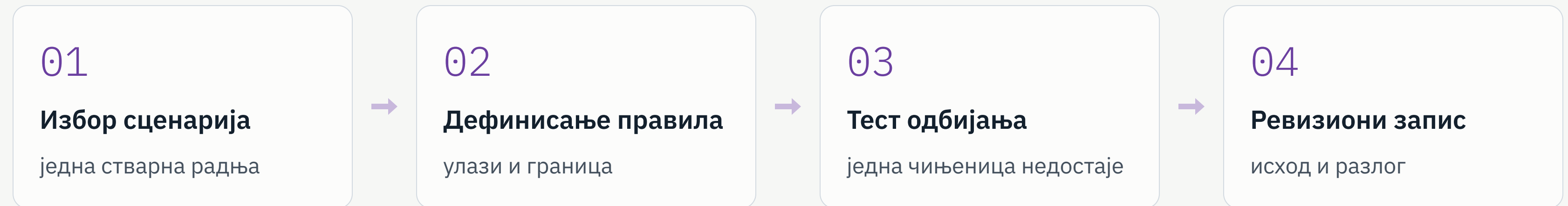
01 Логови разликују технички траг од безбедносно значајног ревизионог записа.

02 Метрика има име, власника и јасно питање које помаже да се одговори.

03 Тајне, токени и непотребни лични подаци не припадају ни логу ни метричкој ознаци.

Примена на пројекат

Анализа једног сценарија обухвата одлуку, имплементацију, тест одбијања и доказ.



ПРИМЕНА НА ПРОЈЕКАТ

Пројектна примена теме „Политике, конфигурација и безбедносна видљивост“ обухвата једну серверску одлуку, тест одбијања и доказ који други члан тима може да понови.

Провера разумевања

Разумевање теме подразумева објашњење одлуке и доказа независно од конкретног технолошког оквира.

01

Политика

шта организација очекује

02

Конфигурација

како се правило примењује

03

Контрола

механизам заштите

04

Доказ

лог, метрика или тест

ПИТАЊЕ ЗА ПРОВЕРУ

Које безбедносно правило би требало да буде засебан, читљив артефакт у вашој целини и који доказ показује да ради?
Пројектна примена: применити исти модел на једну реалну границу у сопственом пројекту.

Резиме

01	Намера и стање	Политика и конфигурација имају власника, значење и историју.
02	Контрола	Поређење очекиваног и стварног производи јасан исход.
03	Видљивост	Лог, метрика и тест повезују правило са стварним понашањем.